CYBERFLOW

Detección conductual y respuesta graduada en redes segmentadas

DETECTA | DECIDE | RESPONDE

Validación técnica interna

Mark · Uziel

UPeU
UNIVERSIDAD PERUANA UNIÓN

Sistema open-source · modelo + heurísticos · feed firmado · nftables

Del problema a los objetivos

EL PROBLEMA

Las firmas reconocen lo conocido.

Pero detectar una anomalía no garantiza una respuesta oportuna ni trazable.

OBJETIVO GENERAL

Desarrollar y validar un sistema open-source que combine análisis conductual, heurísticos y respuesta graduada en una red segmentada.

Pregunta guía *¿Cómo convertir tráfico observado en una decisión verificable?*

01
Caracterizar
tráfico y línea base

02
Evaluar
modelo y umbral

03
Integrar
detección y respuesta

04
Comparar
con Suricata

05
Validar
con evidencia y expertos

Entorno experimental y captura

Primero se levantó la red; después se construyó el detector



01 **CORE-STACK**

Switches físicos · troncales VLAN

VLAN 20 usuarios · VLAN 30 DMZ · VLAN 10 gestión



02 **HOST ESXi**

PG-CYBERFLOW-SPAN

Modo promiscuo · copia entregada a los sensores



03 **SENSOR**

ens37 sin IP

tcpdump → anillo PCAP · Suricata → eve.json

VLAN 20/30 → CORE-STACK → copia SPAN → PG ESXi → ens37 → PCAP + eve.json

ABRIR GUI · RED Y CAPTURA

La NIC de captura no enruta: recibe una copia del tráfico y produce dos fuentes observables.

Cómo se construyó el detector

Una cadena reproducible: datos reales de la red → modelo congelado → despliegue

1. **Capturar** — SPAN → PCAP + eve.json
2. **Depurar** — sin control ni duplicados
3. **Particionar** — bloques temporales + guarda
4. **Comparar** — 7 candidatos + métricas
5. **Calibrar** — umbral en validación
6. **Congelar** — hash + equivalencia + despliegue

335 202

ventanas normales

204 148 / 65 633 / 65 421

entrenamiento · validación · prueba

31 → 28

extraídas → usadas por el modelo

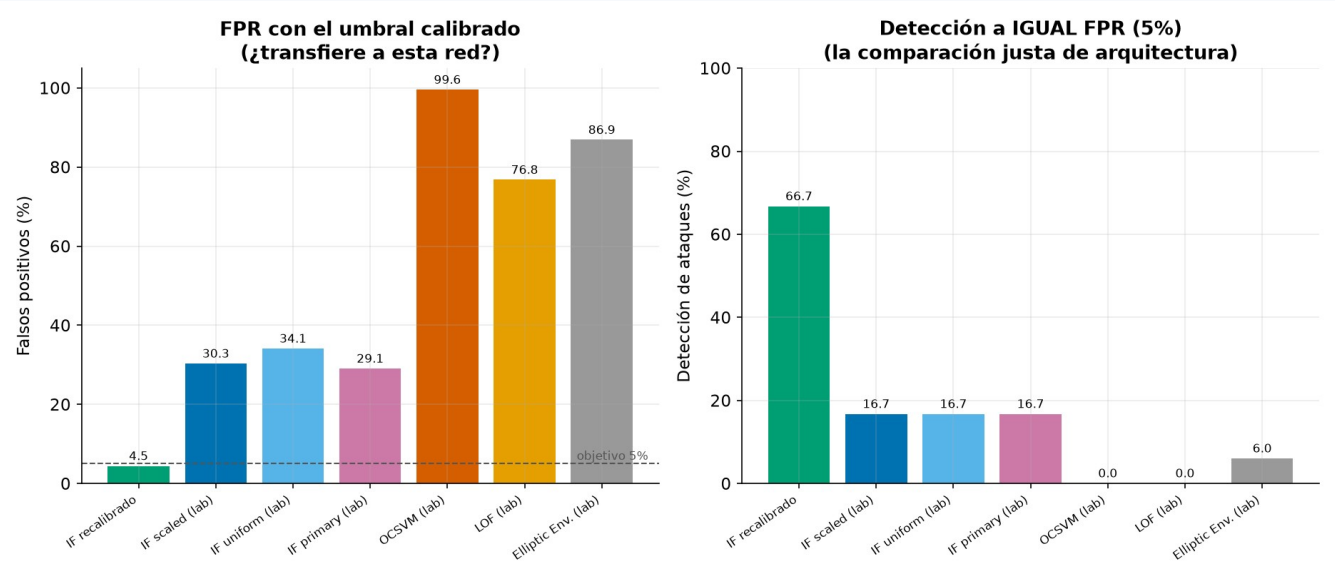
ABRIR EN CYBERFLOW

Construcción y entrenamiento → partición → métricas → congelación → aprobación humana

Fuente: informe de calibración y vista “Construcción y entrenamiento”

Benchmark de modelos sobre esta red

Mismos datos · mismos joblib congelados · sin reentrenar durante la comparación



PROTOCOLO

65 421 normales + 84 ataques · umbral propio: ¿transfiere? · FPR común 5 %: ¿qué arquitectura separa mejor?

GANADOR EN ESTA RED

IF recalibrado

Único con FPR operativo y mejor detección a igual FPR

MÉTRICA	IF RECAL.	OCSVM
ROC-AUC	0,923	0,456
PR-AUC	0,203	0,001
FPR propio	4,45 %	99,57 %
Det. @ FPR 5 %	66,7 %	0,0 %

Con prevalencia de ataque de 0,13 %, Precision y F1 no son el titular: se reportan, pero la decisión se sustenta en ROC/PR-AUC, FPR y detección a igual FPR.

McNemar + Holm: IF recalibrado vs OCSVM/LOF, p < 0,001

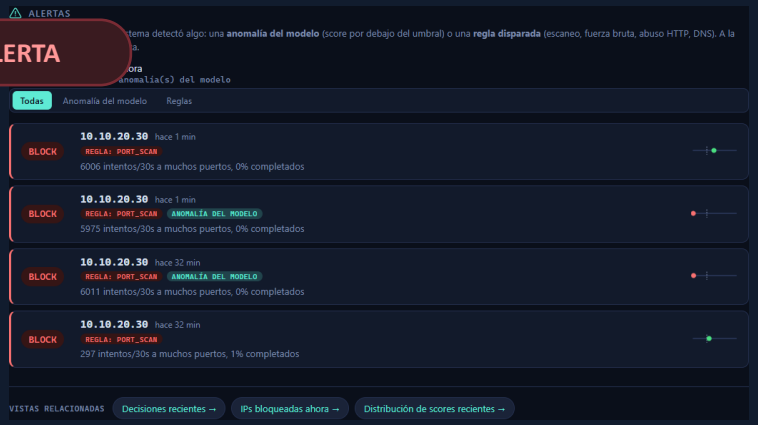
Conclusión: el ganador de laboratorio no transfiere; el IF aprende qué es normal aquí.

CyberFlow en una sola vista

La diapositiva orienta; la evidencia se explica en la GUI

ABRIR GUI

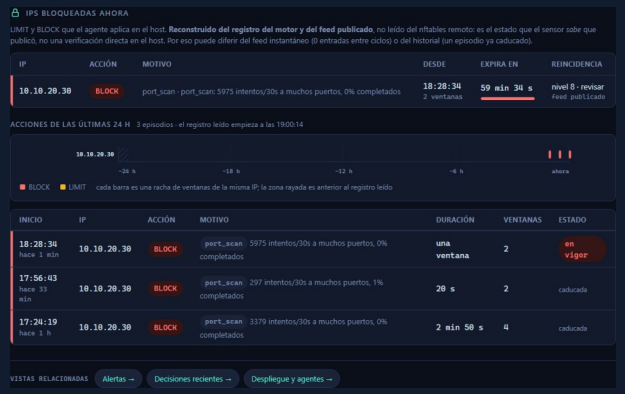
1 · ALERTA



2 · SCORE / UMBRAL



4 · RESPUESTA

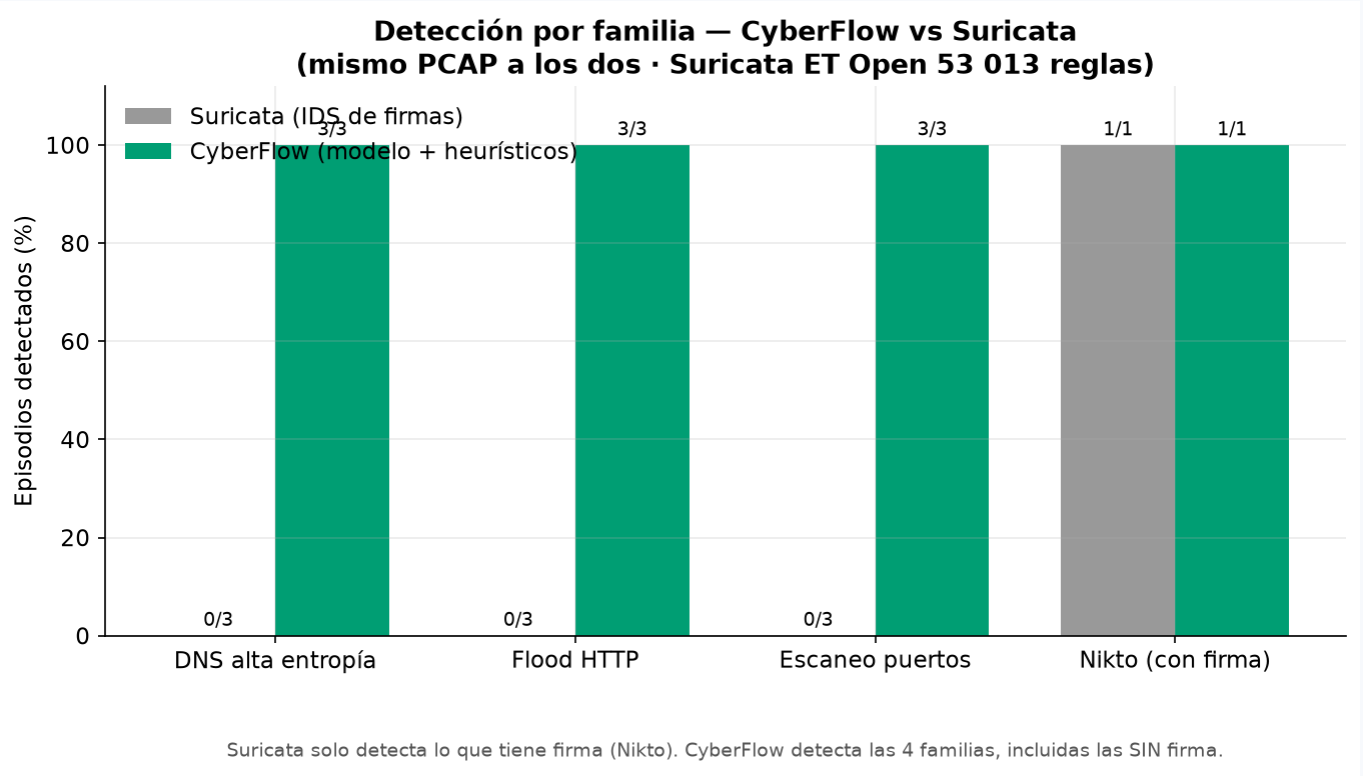


RECORRIDO EN VIVO

- SPAN / PCAP + eve.json
- 28 variables + conteos
- Modelo OR heurísticos
- **PERMIT · LIMIT · BLOCK**

Comparación honesta: precisión frente a cobertura

Mismo PCAP para ambos · Suricata 7.0.3 + ET Open (53 013 reglas)



Tradeoff: Suricata es preciso ante firmas; CyberFlow amplía la cobertura sin firma y responde.

SENSOR1 · EN VIVO

Suricata produce EVE para L7

Sin ruleset de alertas: es fuente del sistema, no el IDS comparador.

VM-SURICATA · COMPARADOR

Replay controlado con ET Open

El mismo tráfico elimina la ventaja de entrada y permite comparar detección.

FPR MEDIDO · 14-OCT

0 FP ET de firma sobre clientes legítimos

11 alertas STREAM fueron artefactos del espejo SPAN, no amenazas. CyberFlow: modelo 4,45 % → LIMIT; heurísticos de BLOCK: 0 FP.

Pendiente: confirmación secundaria con corrida simultánea en vivo.

Suricata y CyberFlow: dos enfoques complementarios

Firmas para lo conocido · comportamiento para lo que se desvía de la normalidad

SURICATA

Detección por firmas

Pregunta: ¿coincide con una regla conocida?

CYBERFLOW

Análisis de comportamiento

Pregunta: ¿se desvía de la línea base o activa un patrón?

DOS PREGUNTAS

¿Coincide? + ¿Se desvía?

FIRMAS + COMPORTAMIENTO

No se sustituyen: juntos amplían la cobertura frente a amenazas conocidas y patrones sin firma.

FORTALEZA

Precisión en lo conocido

Nikto: 1/1 · Sin firma: DNS, flood y escaneo 0/3.

FORTALEZA

Cobertura sin firma

DNS, flood y escaneo: 3/3 · Respuesta LIMIT o BLOCK.

SURICATA: amenazas conocidas + CYBERFLOW: conducta sin firma = mayor cobertura y respuesta

Demo: ataque → evidencia → respuesta

La prueba termina cuando la misma IP, hora, motivo y acción coinciden en toda la cadena

1

ANTES

Kali confirma 443/tcp open

2

ATAQUE

nmap a 3000 puertos

3

DETECCIÓN

port_scan + score < umbral

4

RESPUESTA

feed firmado → agente → nftables

5

DESPUÉS

Kali confirma 443/tcp filtered

CRITERIO DE VALIDACIÓN

GUI = motor_decision.log = feed = nftables

EVALUAMOS

Entorno · producto · evidencia · límites

CAMBIAR A KALI + GUI + TERMINAL